I. PURPOSE

This policy establishes controls related to the Commonwealth's Information Security Incident Response program. The policy provides guidance in decision-making and practices that optimize resources, mitigate risk, and maximize return on investment.

II. DEFINITIONS

"Information Security Incident" – means a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices.

"Security Breach" – means

1. The unauthorized acquisition, distribution, disclosure, destruction, manipulation, or release of unencrypted or unredacted records or data that compromises – or that the agency or nonaffiliated third party reasonably believes may compromise – the security, confidentiality, or integrity of personal information and result in the likelihood of harm to one (1) or more individuals; or

2. The unauthorized acquisition, distribution, disclosure, destruction, manipulation, or release of encrypted records or data containing personal information, along with the confidential process or key to unencrypt the records or data, that compromises – or the agency or nonaffiliated third party reasonably believes may compromise – the security, confidentiality, or integrity of personal information and result in the likelihood of harm to one (1) or more individuals.

   "Security breach" does not include the good-faith acquisition of personal information by an employee, agent, or nonaffiliated third party of the agency for the purposes of the agency, if the personal information is used for a purpose related to the agency and is not subject to unauthorized disclosure. KRS 61.931 (9)(a) and (b).

III. POLICY AND PROCEDURES

Agencies shall notify the Commonwealth Service Desk when they identify a potential security incident. When agencies believe a security incident is sensitive in nature, they shall contact the Commonwealth Office of Technology (COT) Security Office directly. The Office of the Chief Information Security Officer (CISO) shall review the incident and determine its appropriate response to the incident, ranging from an advisory role to leading the investigation.

The Commonwealth Office of Technology (COT) and affected agencies shall adhere to KRS 61.931 through KRS 61.934 and all federal, state, and local laws as well as COT policies to ensure appropriate reporting and remediation of a security breach. COT and agencies shall

protect data and information about the breach in accordance with all applicable laws and policies.

COT, governmental agencies, and non-affiliated third parties that maintain or possess personal information, shall have reasonable security procedures and practices to protect and safeguard that information against security breaches in accordance with KRS 61.931 through KRS 61.934. COT, agencies, and non-affiliated third parties shall follow the procedures and practices of KRS 61.931 through KRS 61.934 for notification and reporting requirements by using the appropriate forms in 200 KAR 1:015 (Data Breach Notification Forms).

COT and agency personnel shall comply with all federal and state laws and policies for information disclosure to the media or the public. COT will work closely with the management of affected agencies to ensure proper disclosure of security incident information. COT personnel and agencies shall not disclose agency data or information related to security incident responses unless required to do so by state or federal regulations.

IV. CORRECTIVE OR DISCIPLINARY ACTION

Each agency shall ensure that all relevant staff within their organizational authority are aware of and comply with this policy. The agency is responsible for enforcing it. Unauthorized and/or neglectful actions regarding this policy may result in disciplinary action up to and including dismissal. COT may require additional service charges for remediation efforts due to non-compliance with this policy.

V. APPLICABILITY

All executive branch agencies and non-executive branch agencies using COT-managed infrastructure or services shall adhere to this policy. This includes employees, contractors, consultants, temporaries, volunteers, and other workers within state government. Organizations may modify this policy to fulfill their responsibilities but must obtain approval through an exception request. Staff should refer to their internal policy that may have additional information or clarification.

VI. REFERENCES

Helpful references can be found on the Enterprise IT Policies webpage.